

KIỂM TRA API 1 & 2 — Auth: Login + Register

YÊU CẦU

Đọc code hiện tại của API 1 (Login) và API 2 (Register), đối chiếu từng điểm trong checklist dưới đây. Với mỗi điểm: ghi ☒ nếu đúng, ☒ + mô tả lỗi nếu sai/thiếu, rồi tự sửa ngay.

SPEC CHUẨN

API 1 • Login (POST /api/v1/auth/login)

Body: {email?, phone?, password} (email hoặc phone, ít nhất 1)

Checklist:

- ☐ Validate: phải có email hoặc phone (không cần cả 2)
- ☐ Validate: password không được rỗng
- ☐ Query tìm user:

sql

```
SELECT u.*, STRING_AGG(r.role_code, ',') AS roles
FROM users u
LEFT JOIN user_roles ur ON ur.user_id=u.user_id AND ur.status='ACTIVE'
LEFT JOIN roles r ON r.role_id=ur.role_id
WHERE (u.email=@email OR u.phone=@phone) AND u.deleted_at IS NULL
GROUP BY u.user_id, u.email, u.phone, u.password_hash, u.full_name, u.avatar_
```

- ☐ Nếu không tìm thấy user → **401** "Email/SĐT hoặc mật khẩu không đúng" (không nói rõ cái nào sai)
- ☐ `bcrypt.compare(password, user.password_hash)` → **401** nếu sai
- ☐ Check `user.status === 'ACTIVE'` → **403** "Tài khoản đã bị khóa" nếu SUSPENDED
- ☐ Tạo `accessToken`: JWT payload `{user_id, roles[], email}`, secret từ ENV, expires ngắn (15m-2h)
- ☐ Tạo `refreshToken`: `crypto.randomBytes(64).toString('hex')` (KHÔNG dùng JWT cho refresh)
- ☐ Lưu refresh token vào DB:

sql

```
INSERT INTO refresh_tokens (user_id, token_hash, device_info, ip_address, expires_at)
VALUES (@uid, hash(@rt), @deviceInfo, @ip, DATEADD(day, 30, NOW()))
```

token_hash = `crypto.createHash('sha256').update(refreshToken).digest('hex')`

☐ `UPDATE users SET last_login_at=NOW() WHERE user_id=@uid`

☐ Response **200**:

json

```
{
  "success": true,
  "data": {
    "access_token": "eyJ...",
    "refresh_token": "abc123...",
    "expires_in": 900,
    "user": {"user_id": 1, "email": "...", "full_name": "...", "avatar_url": null}
  }
}
```

API 2 · Register `POST /api/v1/auth/register`

Body: `{email?, phone?, password, full_name, gender?, birth_date?}`

Checklist:

- ☐ Validate: phải có email hoặc phone
- ☐ Validate: `full_name` không được rỗng
- ☐ Validate: `password` tối thiểu 6 ký tự (hoặc theo quy tắc đã định)
- ☐ Check trùng email (nếu có): `SELECT 1 FROM users WHERE email=@email AND deleted_at IS NULL` → **409** "Email đã được sử dụng"
- ☐ Check trùng phone (nếu có): tương tự → **409** "Số điện thoại đã được sử dụng"
- ☐ Hash password: `bcrypt.hash(password, 10)` — KHÔNG lưu plaintext
- ☐ INSERT users: `(email, phone, password_hash, full_name, gender, birth_date, status='ACTIVE')`
- ☐ Tự động gán role CUSTOMER:

sql

```
INSERT INTO user_roles (user_id, role_id, status)
SELECT @newUserId, role_id, 'ACTIVE' FROM roles WHERE role_code='CUSTOMER'
```

☐ Response **201**:

json

```
{
  "success": true,
  "data": {
    "user_id": 1,
    "email": "...",
    "full_name": "...",
    "roles": ["CUSTOMER"]
  },
  "message": "Đăng ký thành công"
}
```

- ☐ KHÔNG trả password_hash trong response
- ☐ KHÔNG tự động login (không trả token) — user phải gọi API Login riêng

KẾT QUẢ KIỂM TRA

Sau khi đọc code, liệt kê:

1. Những điểm  đã đúng
2. Những điểm  sai/thiếu + code đã sửa
3. Tóm tắt: "API 1 và 2 đã đúng / cần sửa X điểm"